

Digital Signature Systems

IT-Security | 14.04.2026

Gerald Dißbaur | Lecturer

A-SIT Secure Information Technology Center Austria

Agenda

Introduction

Fundamental Principles of Remote Signature Solutions

Requirements and Technical Architecture to Operate QSCDs

Practical Every-day Experiences from eIDAS Certifications

Summary

Agenda

Introduction

Fundamental Principles of Remote Signature Solutions

Requirements and Technical Architecture to Operate QSCDs

Practical Every-day Experiences from eIDAS Certifications

Summary

Do You Have an Identity Card?

DEMONSTRATION OPERATIONAL SYSTEM FROM AUSTRIA

Austrian „*Handy-Signatur*“ and „*Buergerkarte*“¹



Key Figures^{2,3}

- **1.364.939**⁴ Active users which use the system mainly between **07:00 – 20:00**⁵
- More than **80.000 signature creations per 24h** on average
- More than **5.000 signature creations per 1h** on average

Selected Use Cases

- Access e-Government applications (*e.g., finanzonline.gv.at, gesundheitskasse.at*)
- Electronically sign PDF documents legally valid

¹ Annotation: Buergerkarte and Handy-Signatur are mainly the same system with e.g., other Authentication factors. More details are retrievable: <https://www.buergerkarte.at/>

² Source: A-Trust, Retrievable: <https://www.a-trust.at/handystat/> [Accessed: 2020-02-09]

³ Status: 2020-02-10

⁴ Annotation: 3.769.016 people participating in the labor market; Status: 12-2019; Retrievable: <https://www.sozialversicherung.at/odscontent/?contentid=10007.821590&portal=svportal> [Accessed: 2020-02-09]

⁵ Annotation: Mainly on Monday to Friday. Therefore, the presented statistics may vary depending on the date of evaluation.

AUSTRIAN EID OVERVIEW

FACTS AND HISTORY

Introduced in 2005 on a voluntary basis

- Defines functions and enables various technology
- Sector-specific persistent identifiers
- Qualified electronic signature
- Representation on behalf and mandates

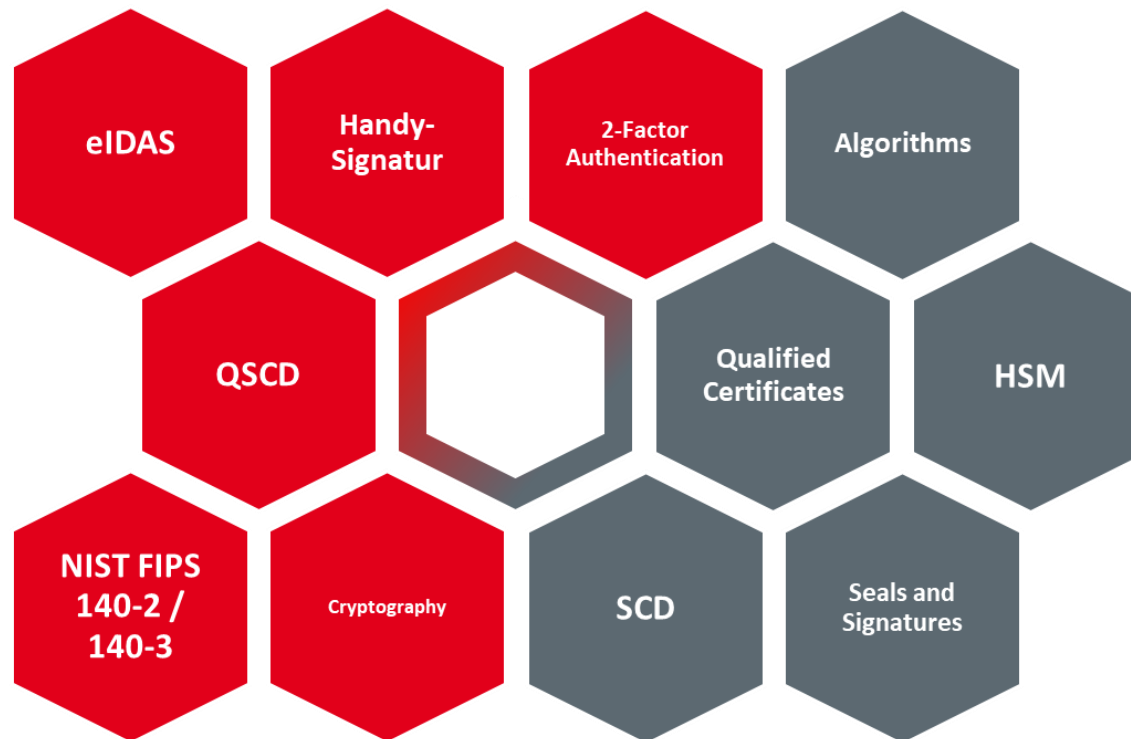
Technology neutral

- Smartcards (*e.g., former eCard*)
- Smartphones (*OS e.g., Android, iOS*)

Redesign is work in progress

- Focus on mobile devices

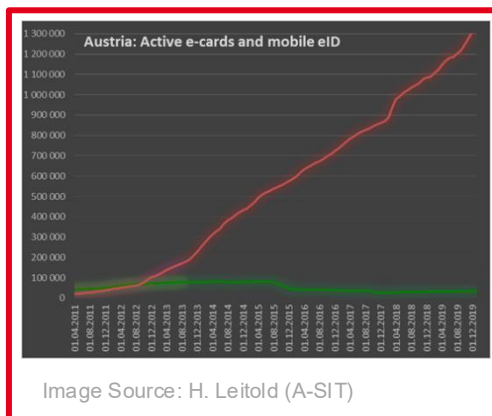
KEYWORDS



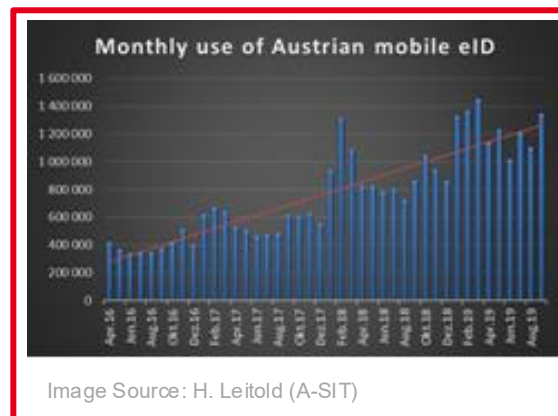
OVERVIEW OF FIGURES

AUSTRIAN STATISTICS | A GREAT SUCCESS STORY

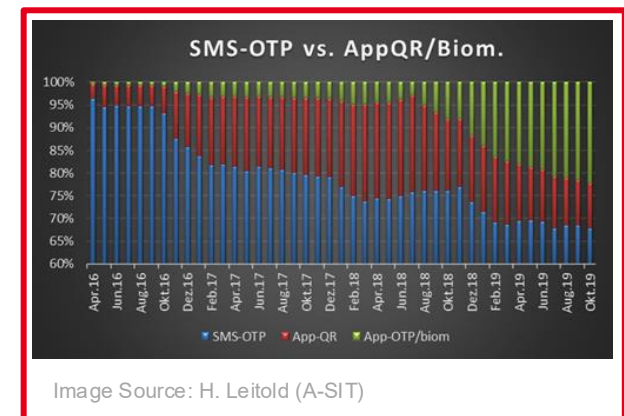
- (1) Austrian active e-Cards and Mobile E-ID
- (2) Monthly use of Austrian Mobile E-ID
- (3) SMS-OTP vs. AppQR/Biometrics



1



2



3

SOME OBSERVATIONS

DIGITAL SIGNATURE SOLUTIONS AND CERTIFICATION

Distinction between two kinds of certifications¹

- (1) IT security **certification based on international standards** (e.g., ISO 15408)
Obtained a lot of experiences in the last decades (e.g., Smartcards)
- (2) **Certification using alternative processes** (international standards are not available e.g., for innovative technologies such as mobile signing solutions, cloud signing) Upcoming innovative solutions where standards are very limited



Smartphone Product Cycle

Smartcard Product Cycle

Certification Requirements Must Not Restrict Required Technology

¹ cf. recital (55), REGULATION (EU) No 910/2014 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL of 23 July 2014 on electronic identification and trust services for electronic transactions in the internal market and repealing Directive 1999/93/EC

Agenda

Introduction

Fundamental Principles of Remote Signature Solutions

Requirements and Technical Architecture to Operate QSCDs

Practical Every-day Experiences from eIDAS Certifications

Summary

RELEVANT LEGISLATION FOR SIGNATURE SOLUTIONS

OVERVIEW | EU AND AUSTRIA | 5 SELECTED LEGAL BASES

EU Level

- REGULATION (EU) No 910/2014 (*eIDAS*)¹
- COMMISSION IMPLEMENTING DECISION² (EU) 2016/650
- COMMISSION DELEGATED REGULATION (EU) 2018/389 (*PSD II*)³ (*if applicable*)

Austrian Legislation

- Signatur- und Vertrauensdienstegesetz – SVG⁴ (*if applicable*)
- Signatur- und Vertrauensdiensteverordnung – SVV⁵ (*if applicable*)

¹ cf. REGULATION (EU) No 910/2014 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL of 23 July 2014 on electronic identification and trust services for electronic transactions in the internal market and repealing Directive 1999/93/EC

² cf. COMMISSION IMPLEMENTING DECISION (EU) 2016/650 of 25 April 2016 laying down standards for the security assessment of qualified signature and seal creation devices pursuant to Articles 30(3) and 39(2) of Regulation (EU) No 910/2014 of the European Parliament and of the Council on electronic identification and trust services for electronic transactions in the internal market

³ cf. COMMISSION DELEGATED REGULATION (EU) 2018/389 of 27 November 2017 supplementing Directive (EU) 2015/2366 of the European Parliament and of the Council with regard to regulatory technical standards for strong customer authentication and common and secure open standards of communication

⁴ cf. Bundesgesetz über elektronische Signaturen und Vertrauensdienste für elektronische Transaktionen (Signatur- und Vertrauensdienstegesetz – SVG, BGBl. I Nr. 50/2016 vom 08. Juli 2016)

⁵ cf. Verordnung über elektronische Signaturen und Vertrauensdienste für elektronische Transaktionen (Signatur- und Vertrauensdiensteverordnung – SVV, BGBl. II Nr. 208/2016)

3 TYPES OF ELECTRONIC SIGNATURES

ELECTRONIC SIGNATURE, ADVANCED, AND QUALIFIED

***‘electronic signature’** means data in electronic form which is attached to or logically associated with other data in electronic form and which is used by the signatory to sign;¹*

***‘advanced electronic signature’** means an electronic signature which meets the requirements set out in Article 26;¹*

***‘qualified electronic signature’** means an advanced electronic signature that is created by a qualified electronic signature creation device, and which is based on a qualified certificate for electronic signatures;¹*

¹ cf. L 257/84, REGULATION (EU) No 910/2014 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL of 23 July 2014 on electronic identification and trust services for electronic transactions in the internal market and repealing Directive 1999/93/EC

QUALIFIED SIGNATURE CREATION DEVICE (QSCD) OPERATED BY TSPS UNDER THE EIDAS REGULATION

‘qualified certificate for electronic signature’ means a certificate for electronic signatures, that is issued by a qualified trust service provider and meets the requirements laid down in Annex I;¹

‘qualified electronic signature creation device’ means an electronic signature creation device that meets the requirements laid down in Annex II;²



¹ cf. L 257/84, REGULATION (EU) No 910/2014 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL of 23 July 2014 on electronic identification and trust services for electronic transactions in the internal market and repealing Directive 1999/93/EC

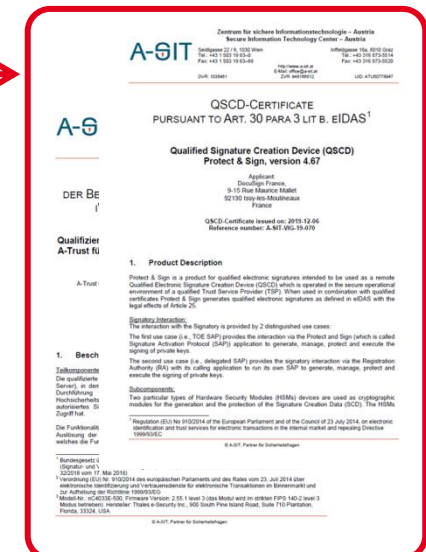
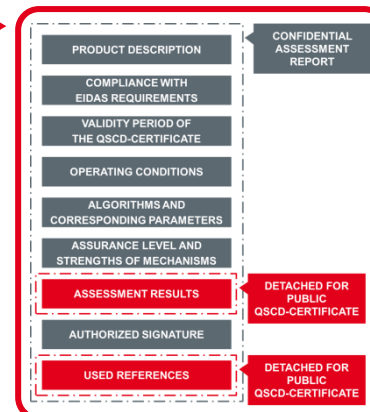
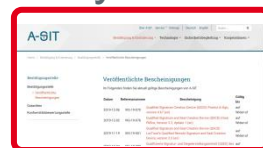
² cf. L 257/85, REGULATION (EU) No 910/2014 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL of 23 July 2014 on electronic identification and trust services for electronic transactions in the internal market and repealing Directive 1999/93/EC

QSCD CERTIFICATE PURSUANT TO ART. 30 PARA 3 LIT B. EIDAS

Certification of qualified electronic signature creation devices

- Conducted by confirmation bodies such as A-SIT (or others)
- A-SIT publishes issued QSCD certificates on its website¹
- Basic Structure of a QSCD Certificate and Report

- Similar structure
- Report has one more headline
- QSCD certificate publicly¹ available (if requested)



¹ Annotation: Published QSCD certificates (see examples above) retrievable: <https://www.a-sit.at/bestaetigung-evaluierung/bestaetigungsstelle/downloads/> [Accessed: 2020-02-09]

Agenda

Introduction

Fundamental Principles of Remote Signature Solutions

Requirements and Technical Architecture to Operate QSCDs

Practical Every-day Experiences from eIDAS Certifications

Summary

EIDAS-REQUIREMENTS FOR QSCDS

REQUIREMENTS FOR QSCDS UNDER THE EIDAS LAYED DOWN IN THE ANNEX II

4 (1) Requirements that include a series of other requirements

1. *Qualified electronic signature creation devices shall ensure, by appropriate technical and procedural means, that at least:*
 - (a) *the confidentiality of the electronic signature creation data used for electronic signature creation is reasonably assured;*
 - (b) *the electronic signature creation data used for electronic signature creation can practically occur only once;*
 - (c) *the electronic signature creation data used for electronic signature creation cannot, with reasonable assurance, be derived and the electronic signature is reliably protected against forgery using currently available technology;*
 - (d) *the electronic signature creation data used for electronic signature creation can be reliably protected by the legitimate signatory against use by others.*

REQUIREMENTS FOR QSCDS UNDER THE EIDAS | cont'd

LAYED DOWN IN THE ANNEX II

4 (2-4) Requirements that include a series of other requirements

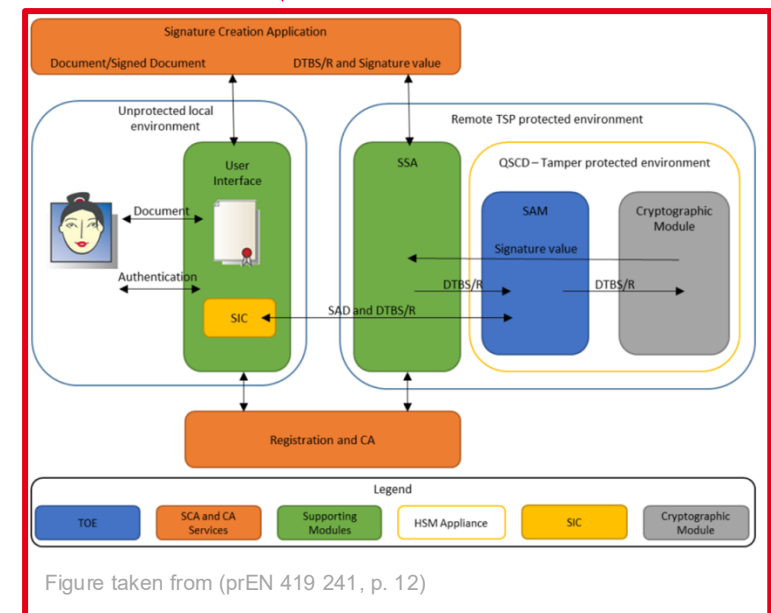
2. *Qualified electronic signature creation devices shall not alter the data to be signed or prevent such data from being presented to the signatory prior to signing.*
3. *Generating or managing electronic signature creation data on behalf of the signatory may only be done by a qualified trust service provider.*
4. *Without prejudice to point (d) of point 1, qualified trust service providers managing electronic signature creation data on behalf of the signatory may duplicate the electronic signature creation data only for back-up purposes provided the following requirements are met:*
 - (a) *the security of the duplicated datasets must be at the same level as for the original datasets;*
 - (b) *the number of duplicated datasets shall not exceed the minimum needed to ensure continuity of the service.*

TECHNICAL ARCHITECTURE OF QSCDS

REMOTE SIGNATURE SOLUTIONS | BASIC ARCHITECTURE

QUALIFIED SIGNATURE CREATION DEVICES (QSCDs)

- **TW4S – Trustworthy System Supporting Server Signing**
- CA – Certification Authority
- DTBS/R – Data to be signed (*representation*)
- HSM – Hardware Security Module
- SAD – Signature Activation Data
- SAM – Signature Activation Module
- SCA – Signature Creation Application
- SIC – Signature Interaction Component
- SSA – Server Signing Application
- TOE – Target of Evaluation
- TSP – Trust Service Provider



TECHNICAL ARCHITECTURE OF QSCDS¹

CRYPTOGRAPHIC PRODUCTS | EXAMPLES

Selected Subcomponents for QSCDs (*the TOE*)

- Hardware Appliance (*e.g., with a dedicated function that includes cryptographic modules*)
- **Cryptographic modules** (*e.g., HSMs* which perform cryptographic operations)
- SAP (*e.g., Software*)
- Operational in protected environments (*e.g., certified data centers, TSPs*)
- Interaction components (*e.g., software*) to interact with remote environments (*e.g., CA, calling application, time stamping authority*)

Signature Creation Data and Signature Validation Data

- SCD/SVD keypairs (*i.e., asymmetric; private/public*)
e.g., created and destroyed for one signature creation process
- Certified security functions of **HSMs** to perform cryptographic operations

¹ Important Annotation: Only publicly available data are taken into account and the practical implementation may differ

HSMS FOR QSCDS

SELECTED EXAMPLES | DIGITAL SIGNATURE SYSTEMS

- SafeNet PCIe Hardware Security Module and SafeNet PCIe Hardware Security Module for SafeNet Network HSM

Firmware Versions: 6.10.7, 6.10.9, and 6.11.2;
Hardware Versions: VBD-05-0100, VBD-05-0101, VBD-05-0103;

#2489

Firmware Versions: 6.24.6 [1] and 6.24.7 [2];
Hardware Versions: VBD-05-0100 [1, 2], VBD-05-0101 [1, 2],
VBD-05-0102 [1, 2] and VBD-05-0103 [1, 2];

#3268



- nShield F3 10+ [1], nShield F3 500+ [2], nShield F3 6000+ [3], nShield F3 500+ for nShield Connect+ [4], nShield F3 1500+ for nShield Connect+ [5] and nShield F3 6000+ for nShield Connect+ [6]

Firmware Versions: 2.51.10-2, 2.55.1-2, and 2.55.2-2
Hardware Versions: nC4033E-010 [1], nC4433E-500 [2],
nC4433E-6K0 [3], nC4433E-500N [4], nC4433E-1K5N [5] and
nC4433E-6K0N [6], Build Standard N

#2149



ASSURANCE OF HSM-SECURITY FUNCTIONS

ASSURANCE LEVEL AND STRENGTHS OF MECHANISMS

NIST FIPS 140-2 VALIDATION CERTIFICATE (NIST and CSEC)

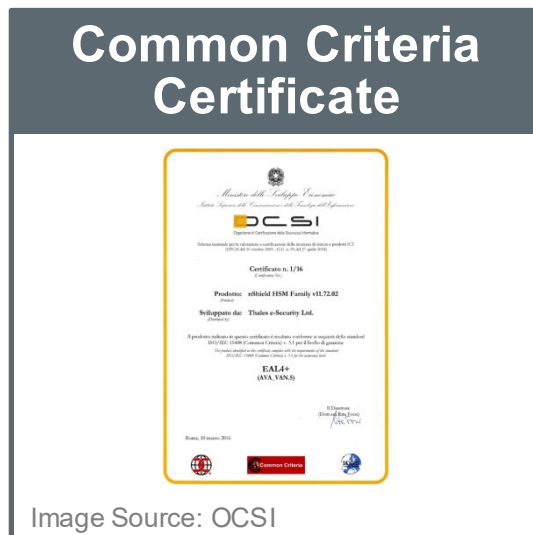


Certificate Number	Validation / Posting Date	Module Name(s)	Vendor Name	Version Information
[...]	[...]	[...]	[...]	[...]
3268	08/24/2018	SafeNet PCIe Hardware Security Module and SafeNet PCIe Hardware Security Module for SafeNet Network HSM	Gemalto	Hardware Version: VBD-05-01 00 [1, 2], VBD-05-0 101 [1, 2], VBD-05-0102 [1, 2) and VBD-05-0103 [1,2]; Firmware Version: 6.24.6 [1] and 6.24.7 [2]

NIST FIPS 140-3 (i.e., the Successor of NIST FIPS 140-2) was Published 03-2019 | 140-3 Effective since 09-2019 | 140-3 Testing begins in 09-2020

ASSURANCE LEVEL AND STRENGTHS OF MECHANISMS

COMMON CRITERIA EAL4+ | SELECTED EXAMPLE



Certificate Number	Validation / Posting Date	Module Name(s)	Vendor Name	Version Information
[...]	[...]	[...]	[...]	[...]
1/16	03/10/2016	nShield HSM Family v11.72.02	Thales e-Security Ltd.	firmware version 2.55.1

Extending a Standard EAL Package with e.g., AVA_VAN.5 is denoted by EAL4+ | '+'

7 ASSURANCE LEVELS ASSIGNED TO GRADE TESTING

EAL4+ WITH ADDED ASSURANCE REQUIREMENTS

	Assurance Level	TOE Assurance Explanation	
 Degree of Assurance - +	EAL 1	Functionally Tested	
	EAL 2	Structurally Tested	EAL 2 / EAL 4 often used for products
	EAL 3	Methodically Tested and Checked	
	EAL 4	Methodically Designed, Tested and Reviewed	
	EAL 5	Semi-Formally Designed and Tested	EAL 5 – EAL 7 require formal methods
	EAL 6	Semi-Formally Verified Design and Tested	
	EAL 7	Formally Verified Design and Tested	

A Higher EAL Does Not Necessarily Imply More Security

CRYPTOGRAPHIC TECHNIQUES AND PARAMETERS

NIST FIPS 140-2 | CRYPTOGRAPHIC TECHNIQUES SUPPORTED CRYPTOGRAPHY BY CERTIFIED HSMS

- Symmetric key algorithms (*AES, EES*)
- Asymmetric key algorithms (*DSA, ECDSA, RSA*)
- Message authentication methods (*CBC-MAC, CCMP, GMAC, HMAC*)
- Hash functions (*SHA-224, SHA-256, SHA-384, SHA-512*)
- Random number generators (*RNG for DSA/ECDSA/RSA*)
- Deterministic random bit generators (*DRBG w.r.t. NIST SP 800-90A Revision 1*)
- Key management (*KAS ECC w.r.t. NIST SP 800-56A Revision 3*)

Why Might One Choose ECDSA Over RSA in Practical Applications?

CRYPTOGRAPHIC ALGORITHMS AND PARAMETERS

SELECTED EXAMPLES OF DIGITAL SIGNATURE SYSTEMS

Asymmetric Cryptography

- RSASSA-PKCS1-v1_5 or RSASSA-PSS¹ and modulus lengths 4096 bits
- RSASSA-PSS (*FIPS PUB 186-4 and RFC 8017*) key lengths 3072 and 4096 Bit
- ECDSA pursuant to FIPS PUB 186-4 with curve P-256 and length of parameters p, q of 256-Bit
- ECDSA with curves (*NIST FIPS PUB 186-4*) P-256, P-384, P-521, K-283, B-283, K-409, B-409, K-571, B-571
- ECDSA with SHA-256, SHA-384 or SHA-512 (*FIPS PUB 186-4*) key length 256, 384 and 512 Bit

Hash Value Computation

- SHA-256 (e.g., pursuant to *ISO/IEC 10118-3*)
- SHA-256, SHA-384 and SHA-512 (*FIPS 180-4*)

***Validate applied techniques and corresponding parameters accordingly
(e.g., SOG-IS Cryptocatalogue or BSI TR-02102-1)***

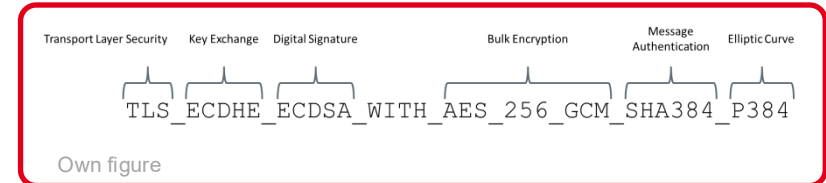
¹ Newer, improved scheme than old scheme to dealing with digital signatures.

TRANSPORT LAYER SECURITY

TLS CIPHER SUITES | EXTRACTED EXAMPLES

Selected Examples for applied TLS 1.2 Cipher Suites

```
TLS_DHE_RSA_WITH_AES_256_CBC_SHA256  
TLS_DHE_RSA_WITH_AES_256_CBC_SHA256  
TLS_DHE_RSA_WITH_AES_256_GCM_SHA384  
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384  
TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384  
TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384  
TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA384  
TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384  
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384
```



¹ cf. IETF, RFC 8446, The Transport Layer Security (TLS) Protocol Version 1.3, August 2018

5 TLS 1.3¹ AEAD CIPHER SUITES PARTICULAR EXAMPLES | recap

- TLS_AES¹_256_GCM²_SHA384
- TLS_CHACHA20³_POLY1305⁵_SHA256
- TLS_AES_128_GCM_SHA256
- TLS_AES_128_CCM_8_SHA256
- TLS_AES_128_CCM_SHA256



TLS 1.3 (i.e., the TLS 1.2 Successor) was Published as RFC 8446⁶ in 08-2018

¹ AES – Advanced Encryption Standard

² GCM – Galois Counter Mode

³ CHACHA20 – A 256 bit 20 round Stream cipher and a variant of Salsa20 where ChaCha is the family of stream ciphers

⁴ BEAST – Browser Exploit Against SSL/TLS

⁵ CRIME – Compression Ratio Info-leak Made Easy

⁶ cf. IETF, RFC 8446, The Transport Layer Security (TLS) Protocol Version 1.3, August 2018

OPERATING CONDITIONS FOR QSCDS

OPERATING CONDITIONS FOR QSCDS

SELECTED EXAMPLES | DEFINED VENDOR-SPECIFICALLY

- The **QSCD** must be **operated** by a **qualified trust service provider** under the **eIDAS** regulation
- The qualified trust service provider must **operate** the **QSCD** in a **protected environment**
- **Restrict** the **physical access** to the **QSCD**
- **Protection against** the possibility of **attacks** based on compromising electromagnetic radiation
- **Equivalent** high level of **protection** for **all sub-components** (*including components used for security purposes*)
- **Employees** holding trusted roles shall meet the personnel **requirements** defined in **ETSI EN 319 401**
- **Physical** and **IT security** used to host and operate the QSCD components shall be compliant with **ETSI EN 319 401**
- **HSMs** must be **initialised** and **operated** according to their **FIPS 140-2 level 3** or **Common Criteria EAL4+ certification**
- [...]

***The Validity Until Further Notice of an Issued QSCD Certificate is
Bound to the Operating Conditions and Other Limitations***

Agenda

Introduction

Fundamental Principles of Remote Signature Solutions

Requirements and Technical Architecture to Operate QSCDs

Practical Every-day Experiences from eIDAS Certifications

Summary

EXPERIENCES FROM EIDAS CERTIFICATIONS

CONSOLIDATED OBSERVATIONS FROM PRACTICE

- **Increasingly used** remote signature solutions in the market (*eIDAS*)
- **Observed higher dynamics** in the **technology environment** for remote-QSCDs than for Smartcards
- **Accelerated transition** from SMS-OTP¹ to **Biometrics** (*e.g., FaceID, TouchID*)
- **Pushback effect** of both **SMS-OTP** and **AppQR**² triggered by increasing Biometric Authentication via App (*i.e., AppBiometric*)

When did You Loose Your Smartphone the Last Time? Recognized it?

¹ SMS-OTP – Short Message Service One-Time-Password

² AppQR – Application Quick Response (*Code*)

EXPERIENCES FROM EIDAS CERTIFICATIONS | cont'd

CONSOLIDATED OBSERVATIONS FROM PRACTICE

- **Similar principle** for certified QSCD-solutions
(e.g., certified HSMs apply cryptographic operations to perform critical signature creation)
- **Differences in the environments** (e.g., HSM-environment) for certified remote-QSCDs
- **SCD¹ are protected by hardware elements in practice**
- **Sole control** for the signatory via **multi-factor authentication** (e.g., biometric, knowledge, possession) **Examples:** FaceID/TouchID, Passphrase, Device-Possession
- Selected **corporations² obtained certifications** for **remote-QSCDs**
A-Trust (AT), DocuSign (FR), Intesi (IT), LuxTrust (LU), PrimeSign (AT), Swisscom (CH) – and others

¹ SCD – Signature Creation Data

² Retrievable: <https://ec.europa.eu/futurium/en/content/compilation-member-states-notification-sscds-and-qscds> [Accessed: 2020-02-09]

Agenda

Introduction

Fundamental Principles of Remote Signature Solutions

Requirements and Technical Architecture to Operate QSCDs

Practical Every-day Experiences from eIDAS Certifications

Summary

SUMMARY

COVERED TOPICS

- **Demonstrated** operational digital signature system „*Handy-Signatur*“ using **FaceID** to electronically sign pdf documents with a qualified electronic signature
- **Clarified** basic **terminology** and **requirements** under the **eIDAS** regulation
- **Explored** **security requirements** under the applicable law
- **Presented** the basic **technical architecture** of remote **QSCDs**
- **Identified** **Cryptographic algorithms**, corresponding **parameters** and **strengths of mechanisms** that are applied to derive qualified electronic signatures and protect the assets inside of a digital signature system
- **Extracted** concrete **examples** of **hardware modules** that **perform cryptographic operations** in **tamper-resistant environments**
- **Derived** vendor-specific **operating conditions** for trust service providers
- **Discussed** **experiences** from conducted projects and QSCD certifications

